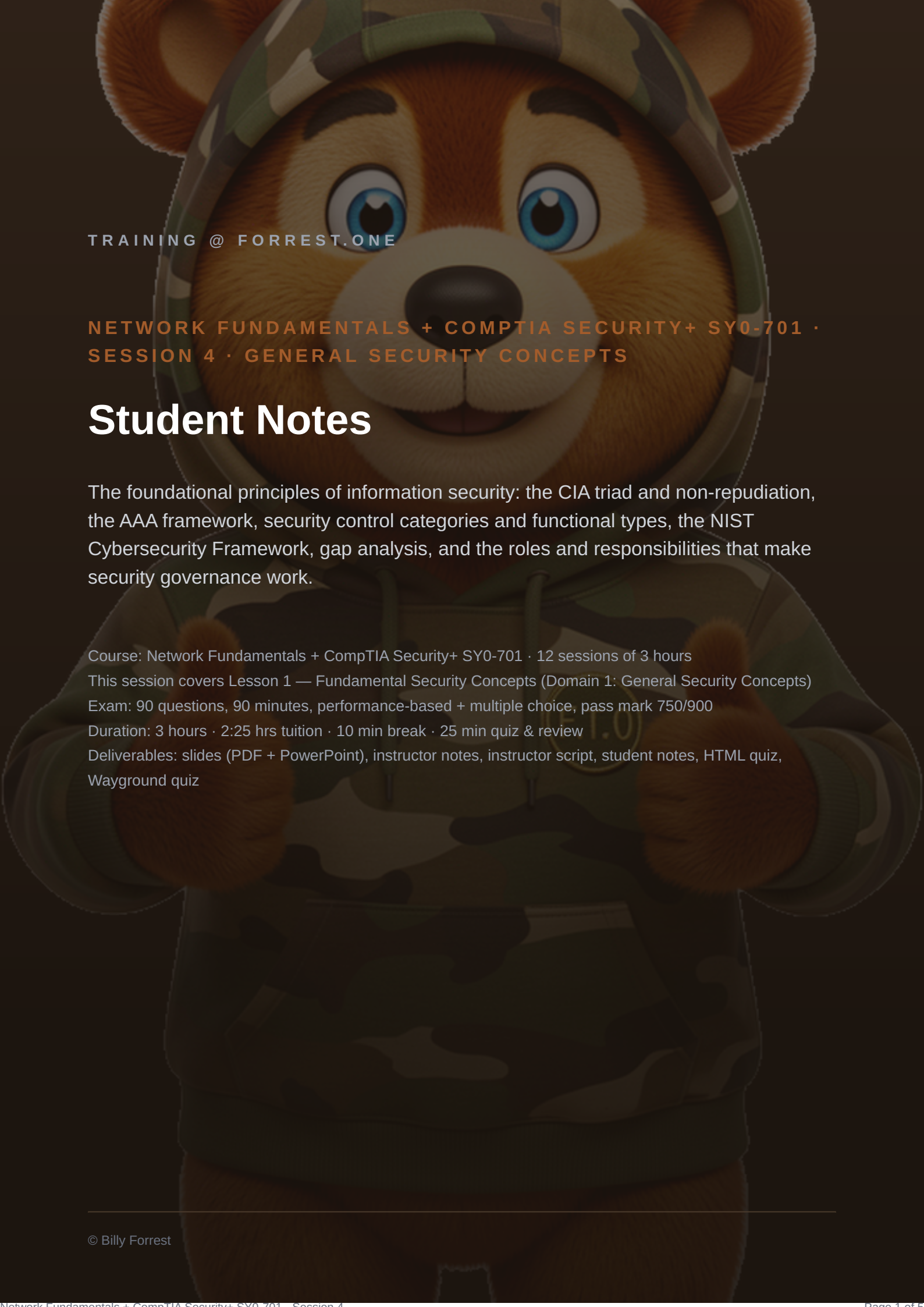




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 4 · GENERAL SECURITY CONCEPTS

Student Notes

The foundational principles of information security: the CIA triad and non-repudiation, the AAA framework, security control categories and functional types, the NIST Cybersecurity Framework, gap analysis, and the roles and responsibilities that make security governance work.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 1 — Fundamental Security Concepts (Domain 1: General Security Concepts)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Student Notes, Security Controls, Concepts & Zero Trust

Your revision guide for Session 4 (Lesson 1 · Domain 1, 12% of the exam). Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready. This session follows six chapters: why controls exist, classifying controls by category, what each control type does, proving identity, accounting and zero trust, and deception and change control.

Key terms

Term	Definition
Security control	A safeguard or countermeasure that manages risk to an asset
Defence in depth	Layered controls, so no single point of failure; layers fail independently
Technical control	Implemented in hardware or software, firewalls, encryption, ACLs, IDS
Physical control	Protects premises, hardware and people, locks, fences, cameras, mantraps
Managerial control	Policy and procedure, risk assessment, security policy, training
Operational control	Day-to-day work by people, guard patrols, incident response, backups
Preventive / detective / corrective	Operates before / during / after an incident
Compensating control	Substitutes when the proper control is not feasible
Deterrent control	Discourages an attempt psychologically, banners, visible cameras
Directive control	Guides your own people, acceptable use policy, procedures
Confidentiality	Information is disclosed only to those with the right permission
Integrity	Data is accurate, complete and unaltered without authorisation
Availability	Authorised users can reach systems and data when they need them
Non-repudiation	Persons cannot deny creating or modifying data, proof of origin and action
Authentication factors	Something you know, something you have, something you are
Accounting	Recording user activity and resource use, producing the audit trail
Audit trail	A chronological record that traces an action back to a specific user
Zero trust	Never trust, always verify, no user or device trusted by default

Term	Definition
Microsegmentation	Isolated network zones that block lateral movement
Honeypot / honeynet / honeytoken	Decoy system / decoy network / single piece of fake data
Change management	Request, impact assessment, approval, scheduled implementation and rollback
Gap analysis	Comparing current posture against a target framework to find gaps
Least privilege	Users receive only the access their role requires
Separation of duties	No one person controls a critical process alone

Core concepts

Chapter 1, Why controls exist

A control is any safeguard or countermeasure that manages risk. Threats are external (a ransomware crew) and internal (a trusted employee copying files). Controls prevent access, detect activity, or respond to incidents, and they span technology, policy, procedure and physical barriers. One control is never enough, which is the layered view: a firewall at the edge, an intrusion detection system behind it, and logs holding the evidence. Layers fail independently, and that independence is the point: backups survive ransomware even when prevention does not.

Chapter 2, Control categories (how a control is delivered)

Technical: built into hardware or software, enforced with no person in the loop (firewall, encryption, ACLs, IDS). Physical: protects premises, hardware and people (locks, fences, cameras, mantrap, biometric door access). Managerial, also called administrative: risk assessment, security policy and training, which set direction for technology to enforce. Operational: the day-to-day work carried out by people (guard patrols, incident response, backup routines, copies held on site and off site). Managerial writes the policy, operational carries it out.

Chapter 3, Control types (what a control does)

Preventive acts before, and is never perfect, so pair it with detection: firewall, encryption, training, segmentation. Detective finds what prevention missed: log monitoring, intrusion detection using signatures and anomalies, security audits. Corrective repairs damage: patch, restore from backup, and revise the procedures that failed (the step organisations skip). Compensating substitutes when the proper control is not feasible, for example a secure gateway for a legacy system that cannot encrypt, enhanced logging where there is no budget, cameras where production cannot stop; it is temporary by intent and must be documented and replaced. Deterrent discourages psychologically: warning banners, visible cameras, security personnel, and it fails against an attacker who does not care. Directive guides your own people: acceptable use policy and procedures, where non-compliance is a management issue.

Chapter 4, Proving identity and keeping records

The CIA triad: confidentiality (only authorised parties read the data), integrity (data is accurate, complete and unaltered), availability (systems and data are reachable when needed). Threats and answers: confidentiality falls to data breaches and eavesdropping, answered by encryption and strong authentication; integrity falls to tampering and man in the middle, answered by hashes, signatures and version control; availability falls to denial of service and hardware failure, answered by redundancy, failover and tested backups. Non-repudiation gives proof of origin: a digital signature is a hash encrypted with the sender's private key, verifiable with the matching public key, with audit logs and timestamps completing the proof. Authentication rests on three factors (know, have, are), and multifactor means two or more different factors: two passwords are not MFA. Protocols to know: Kerberos, LDAP, SAML and SSO.

Chapter 5, Accounting and zero trust

Accounting records who did what and when, producing the audit trail. It creates accountability, supports investigation after an incident, demonstrates compliance and reveals policy violations. Log management centralises logs for correlation, sets a retention period that satisfies regulation, and analyses them with automated alerting; a SIEM collects and correlates events, because a log nobody reads is evidence you will not have. Zero trust removes implicit trust: threats exist inside the network too, so no user and no device is trusted by default and every request is verified. Microsegmentation blocks lateral movement, continuous verification re-checks behaviour and context with adaptive authentication, and least privilege grants only what the role requires. Zero trust is a design principle, not a product.

Chapter 6, Deception and change control

A honeypot is a decoy system that mimics a real one, a honeynet is a network of decoys, and a honeytokens is fake data or a fake account. Contact with a decoy is suspicious by definition, because no legitimate user should ever reach one. Deception buys early warning, threat intelligence and wasted attacker effort. Change management has four steps: request, impact assessment (security, functionality, performance), approval by the system owner and security officer, and scheduled implementation with a rollback plan, all documented. Skipping it produces back doors nobody recorded and configuration drift away from the approved baseline. Four technical implications: allow list, firewall rules, security baseline and system dependencies. Test in a non-production environment and evaluate security impact before approving.

Memory aids

- Controls on two axes: category says how (technical, physical, managerial, operational); type says what (preventive, detective, corrective, compensating, deterrent, directive).
- When does it act? Preventive before, detective during, corrective after.
- CIA: confidentiality is the read side, integrity the change side, availability the access side.
- AAA: the user is identified, then authenticated, then authorised, then accounted.
- Non-repudiation means deniable, no: signatures and logs make denial fail.
- Zero trust: never trust, always verify. A design principle, not a product.
- Deception sizes: pot is one system, net is many, token is one piece of fake data.
- Change control in four words: request, assess, approve, schedule. Then document.

Practical cautions

- Do not confuse integrity (unchanged) with correctness (true).
- Do not confuse preventive (blocks) with deterrent (discourages).
- Do not confuse managerial (writes policy) with operational (carries it out).
- Do not forget corrective has three parts: patch, restore, and revise the procedure.
- Do not treat a vulnerability scan as a gap analysis: they measure different things.
- Do not expect zero trust to be a product: it is a design principle.
- Do not approve a change with no rollback plan, and do not test in production.
- Do not confuse the data owner (accountable) with the custodian (implementer).

Self-check questions

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 4

- Know the two-axis control model cold: category and functional type, with one concrete example for each.
- Non-repudiation is a favourite exam term: link it to signatures and logs, not logging alone.
- Learn the classic paired distinctions: preventive versus deterrent, integrity versus correctness, owner versus custodian, scan versus gap analysis, managerial versus operational.
- Zero trust is described as a design principle: reject any option that sells it as a product.
- Remember the change-management answer: assess and test before approval, and always have a rollback plan.
- The exam is vendor-neutral: no product-specific questions.
- Learn the exam facts: 90 questions, 90 minutes, pass mark 750.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, Domain 1.
- NIST Cybersecurity Framework (CSF 2.0) documentation.
- NIST SP 800-53, security and privacy controls catalogue.
- NIST SP 800-207, Zero Trust Architecture.
- NIST SP 800-61, incident handling guide (for change and incident procedures).